```
Loaded 12 data files. 6639 incidents, 5972 prelabels, 1200 adjudications, 16000 poste
rior draws. Ready.
```

# What the Data Says About the 2026 Top 10

## Act 1: The Question

The OWASP Top 10 for LLMs ranks AI security vulnerabilities. The 2025 list was built from expert surveys — hundreds of security professionals voting on what matters most. That process produced a consensus: Prompt Injection at #1, Sensitive Information Disclosure at #2, and so on down to #10.

Expert opinion is one signal. We wanted to check it against a second signal: the pattern of real-world incidents. We built a corpus of ~6,600 AI security incidents from public databases, classified each one against the 20-entry taxonomy, and asked: does the incident data agree with the experts?

This notebook walks through that analysis step by step. Along the way, you will see how the classification worked, how we measured its accuracy, and what a Bayesian model does with noisy measurements. Every chart and table below is computed live from the data — you can re-run any cell to verify.

Here are the 20 taxonomy entries we are working with. The "Incident Rank" column is blank for now. We will fill it in Act 6, after walking through the methodology.

20 taxonomy entries. Incident Rank will be filled in Act 6.

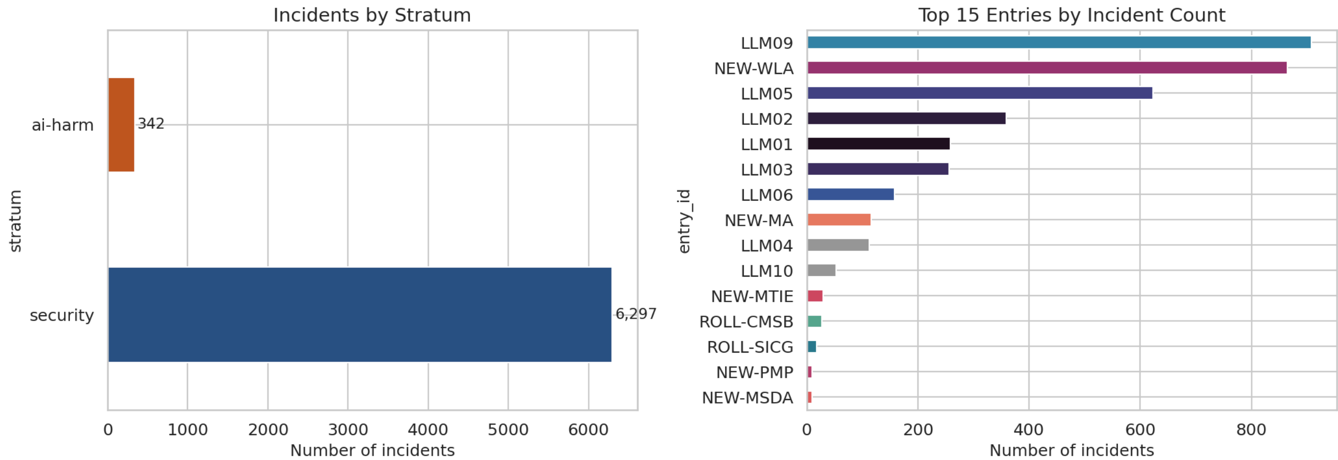
| # | Entry ID | Name | Incident Rank |
|---|---|---|---|
| **1** | LLM01 | Prompt Injection | — |
| **2** | LLM02 | Sensitive Information Disclosure | — |
| **3** | LLM03 | Supply Chain Vulnerabilities | — |
| **4** | LLM04 | Data and Model Poisoning | — |
| **5** | LLM05 | Improper Output Handling | — |
| **6** | LLM06 | Excessive Agency | — |
| **7** | LLM07 | Hidden Context Exposure | — |
| **8** | LLM08 | Vector and Embedding Weaknesses | — |
| **9** | LLM09 | Misinformation | — |
| **10** | LLM10 | Unbounded Consumption | — |
| **11** | NEW-PMP | Persistent Memory Poisoning | — |
| **12** | NEW-MTIE | MCP Tool Interface Exploitation | — |
| **13** | NEW-MA | Model Misalignment | — |
| **14** | NEW-ITSCD | Inference-Time Side-Channel Disclosure | — |
| **15** | NEW-WLA | Weaponized LLM Abuse | — |
| **16** | NEW-MSDA | Model Scheming and Deceptive Alignment | — |
| **17** | ROLL-CMSB | Cross-Modal Safety Bypass | — |
| **18** | ROLL-LAPTF | LLM Artifact Promotion Trust Failure | — |
| **19** | ROLL-SICG | Systemic Insecure Code Generation | — |
| **20** | ROLL-CFAS | Compositional Fine-tuning Alignment Subversion | — |

# Act 2: The Corpus

The corpus contains 6,639 incidents from public databases: CVE, GHSA, and OSV (security advisories), plus AIAAIC (a database of AI-related harms and controversies). Each record has a text description of what happened.

The corpus splits into two strata. The **security** stratum (CVE/GHSA/OSV) contains things like prompt injection exploits, data leakage through APIs, and supply chain compromises in ML packages. The **ai-harm** stratum (AIAAIC) contains things like algorithmic discrimination, deepfake misuse, and surveillance overreach.

This split matters. The classifier performs differently on each stratum — security incidents have more structured descriptions (CVE format), while ai-harm incidents are written as news summaries with varying detail.




## Example: Security stratum (CVE/GHSA/OSV)

**Security incident**

`INC-01335` · consensus: **LLM02** · tier: agree

LibreChat — Vulnerability (CVE-2026-31950) LibreChat is a ChatGPT clone with additional features. In versions 0.8.2-rc2 through 0.8.2-rc3, the SSE streaming endpoint `/api/agents/chat/stream/:streamId` does not verify that the requesting user owns...

## Example: AI-harm stratum (AIAAIC)

**AI-harm incident**

`INC-01746` · consensus: **LLM09** · tier: agree

Romanian Tax Authority's Use of AI in Dispute Resolutions Leads to Legal Rights Violations Romania's tax authority has increasingly used AI systems to generate legal arguments in tax dispute resolutions. These AI-generated outputs often include...

▶ **Deep dive: What the corpus cannot see (F-frame)**

**Structural limitation: taxonomy-frame circularity (F-circ)**

We classified these incidents using the same taxonomy we are trying to validate. If the classifier systematically favors certain entries, the incident counts will appear to confirm the expert rankings even if the true pattern is different. This is taxonomy-frame circularity. It means the concordance we measure later is an upper bound on true agreement, not a precise estimate of it.

# Act 3: Classification — How We Labeled 6,600 Incidents

Each incident was classified by three different large language models: Qwen 235B, Llama 405B, and DeepSeek V3. Each model independently read the incident text and assigned it to one of the 20 taxonomy entries — or marked it "out of scope" if none fit.

When all three models agreed on the same entry, we call it **agree tier**. When two agreed and one differed, **split tier**. When all three picked different entries, **disagree tier**.

The tier tells us how confident we can be in the classification. Agree-tier incidents have strong consensus. Disagree-tier incidents sit in ambiguous territory where even three independent classifiers could not converge.

## Worked example: three-model classification

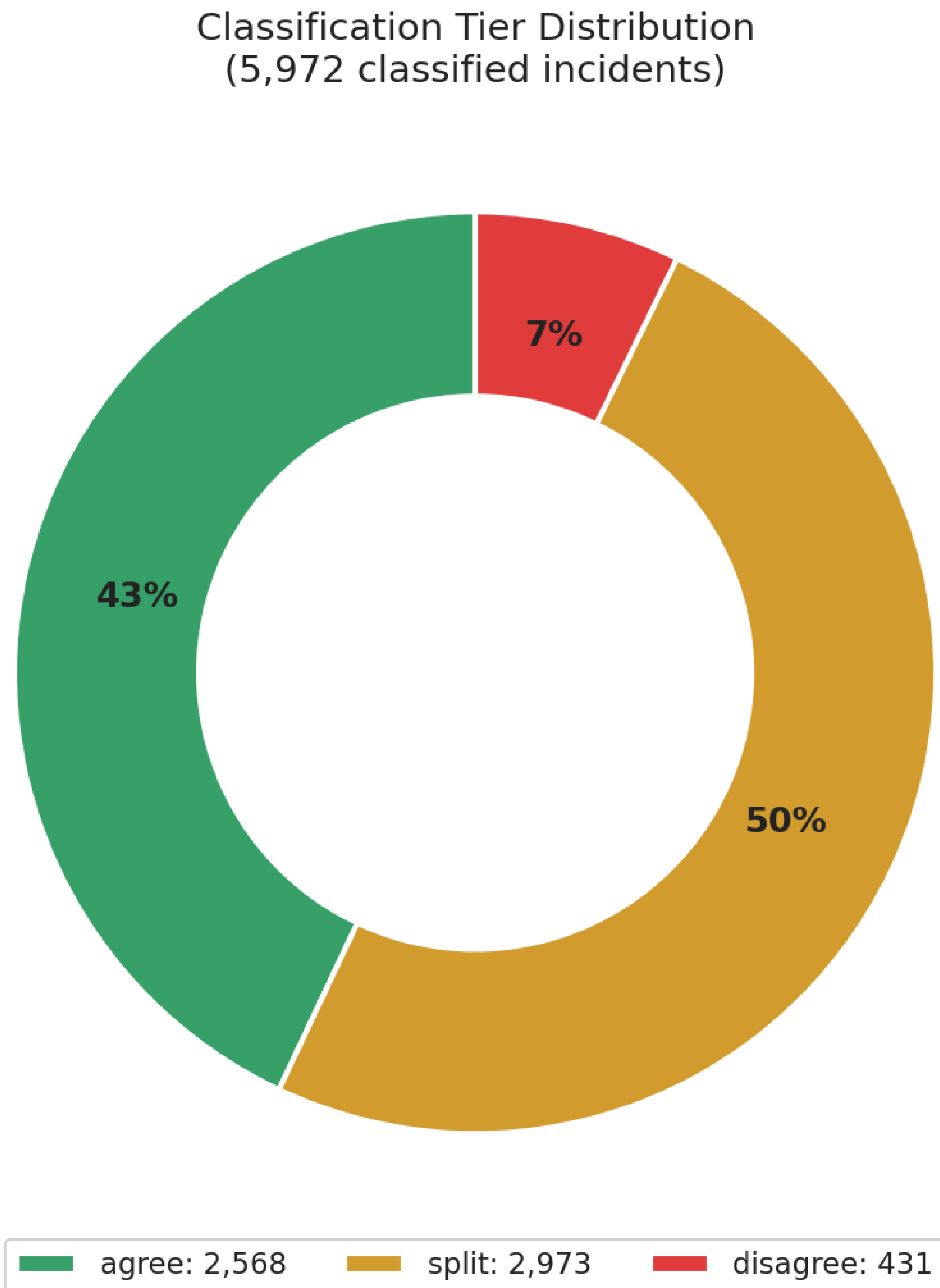
**Incident text** (truncated):

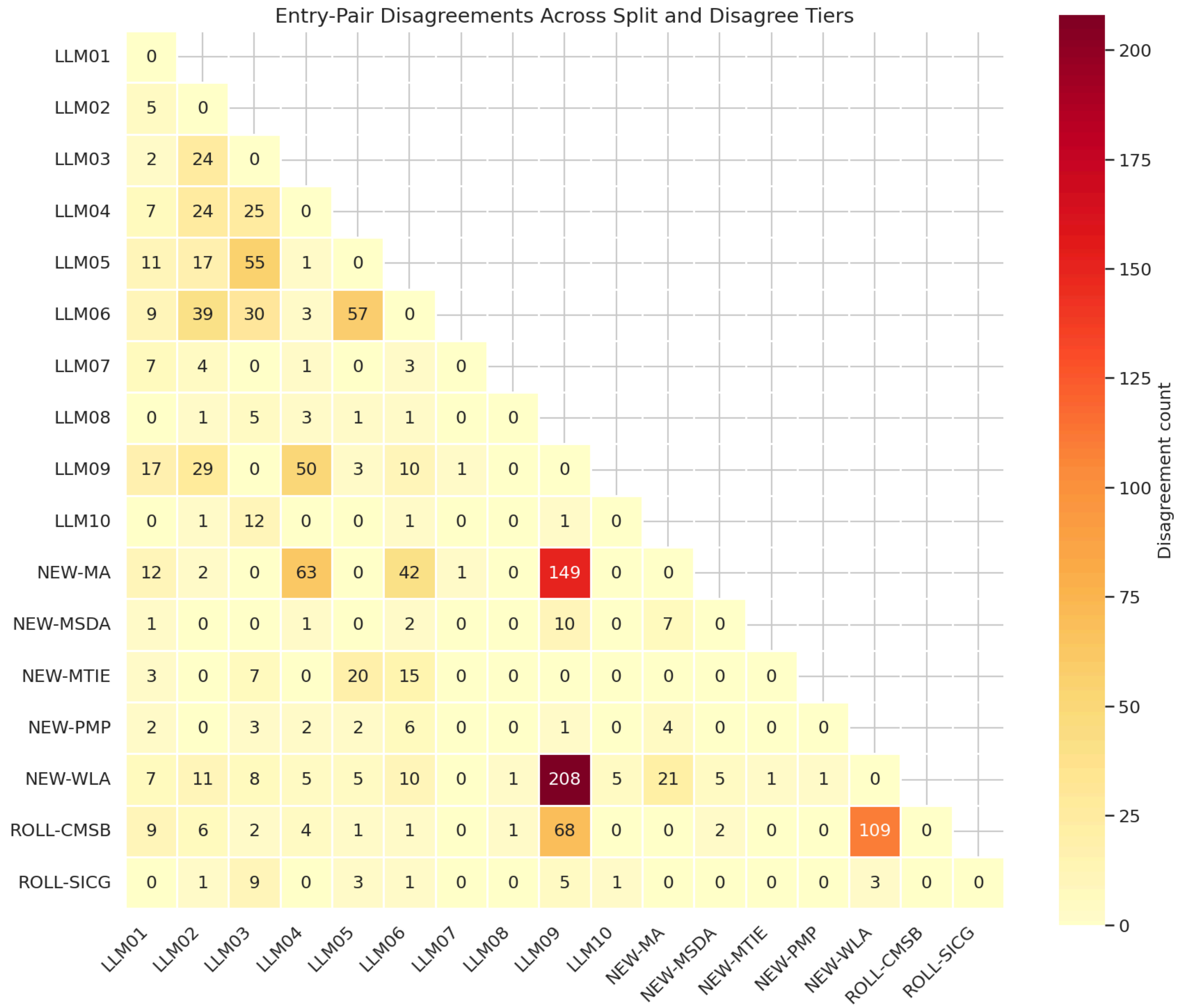
*LibreChat — Vulnerability (CVE-2026-31950) LibreChat is a ChatGPT clone with additional features. In versions 0.8.2-rc2 through 0.8.2-rc3, the SSE streaming endpoint `/api/agents/chat/stream/:streamId` does not verify that the requesting user owns...*

---

| Model | Entry | Confidence |
|---:|---:|---:|
| Qwen3-235B-A22B | **LLM02** | 95% |
| Llama-3.1-405B-Instruct-FP8 | **LLM02** | 100% |
| DeepSeek-V3 | **LLM02** | 95% |

Consensus: **LLM02** (tier: agree)


Classification Tier Distribution
(5,972 classified incidents)
7%
43%
50%
agree: 2,568
split: 2,973
disagree: 431




▶ **Deep dive: Why three models?**

▶ **Deep dive: The two-stage classification pipeline**

# Act 4: How Good Is the Classifier?

The classifier is a tool, not ground truth. To trust the incident counts, we need to measure how often the classifier gets it right — and how often it misses things.

**Precision**: When the classifier says "this incident belongs to LLM02," how often is it correct? We verified 323 classifications by hand to measure this. Each entry gets its own precision score — some entries are easier to classify than others.

**Recall**: Does the classifier find all incidents of a given type, or does it miss some? A human reviewer adjudicated 1,200 incidents across all tiers to measure this. The reviewer saw the incident text and the three model votes, then decided whether to accept the consensus, override it, or mark the incident as out of scope.

## Why precision varies so much across entries

The chart below shows precision ranging from 93% (LLM01, LLM03) down to 13% (LLM08). The variation is not random — it reflects how cleanly each entry's definition separates it from neighboring categories. Four entries fall **below the 50% threshold**, which deserves explanation:

- **LLM08 (Vector and Embedding Weaknesses): 13%.** This is the lowest precision in the taxonomy. Out of every 8 incidents the classifier labels as LLM08, only 1 actually is. The category describes a narrow class of attacks — adversarial manipulation of embedding spaces, vector database poisoning, retrieval-augmented generation exploits. But the classifier confuses it with LLM03 (Training Data Poisoning) and general data integrity issues. Most incidents classified here describe data manipulation that affects a model, which is conceptually adjacent but taxonomically distinct.

- **LLM07 (System Prompt Leakage): 31%.** The classifier struggles to distinguish "extracting a system prompt" (LLM07) from "overriding a system prompt" (LLM01, Prompt Injection). Both involve adversarial interaction with the prompt layer, and many real incidents involve both — an attacker extracts the system prompt *in order to* craft a better injection. The boundary is taxonomically clear but operationally blurred.

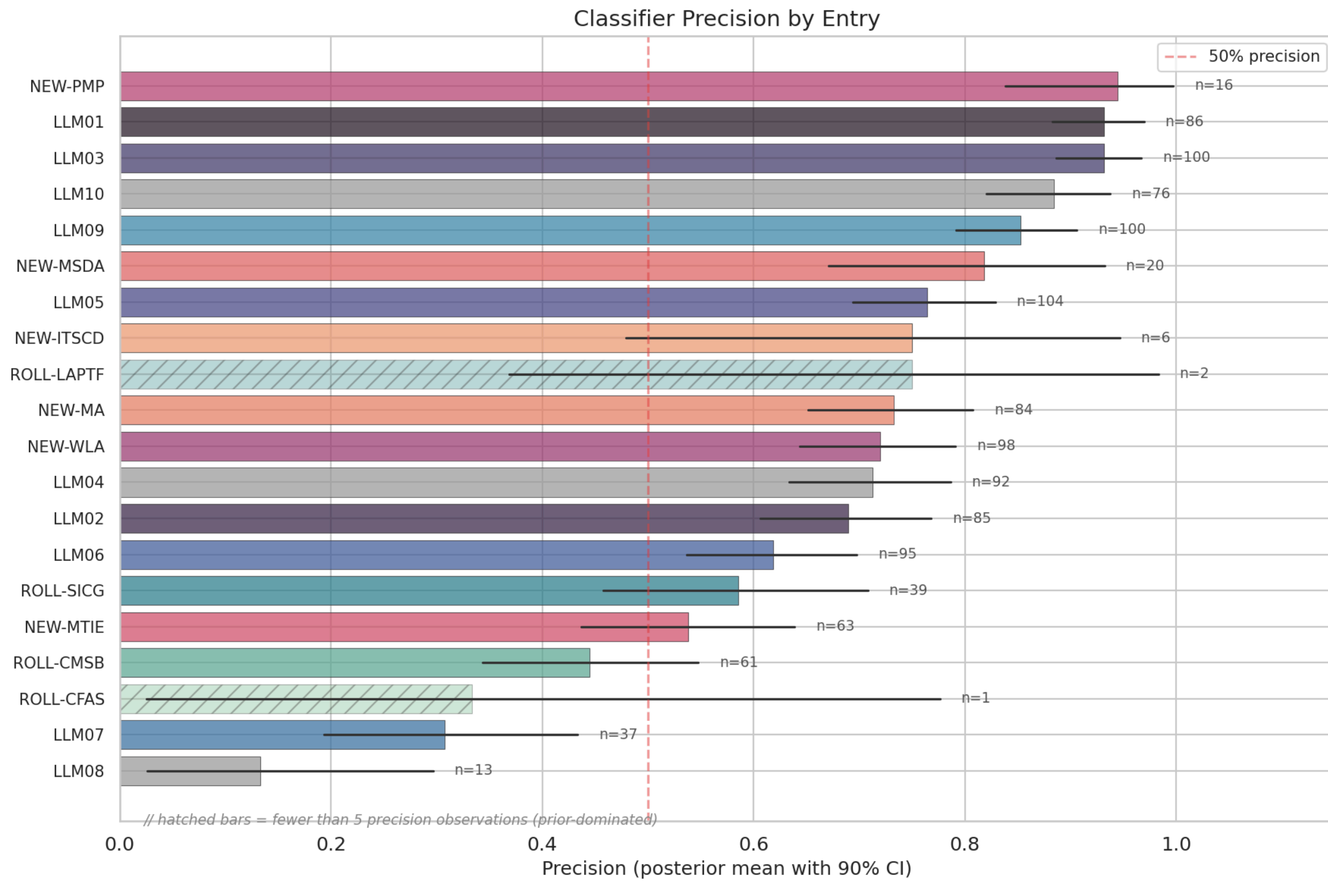
- **ROLL-CFAS (Comprehensive Framework Attacks): 33%.** Only 3 precision observations — the posterior is dominated by the Beta(1,1) prior, so the 33% estimate has a 90% CI stretching from 3% to 78%. The category's broad definition ("attacks on the comprehensive AI framework") makes it a natural catch-all that absorbs incidents from adjacent entries.

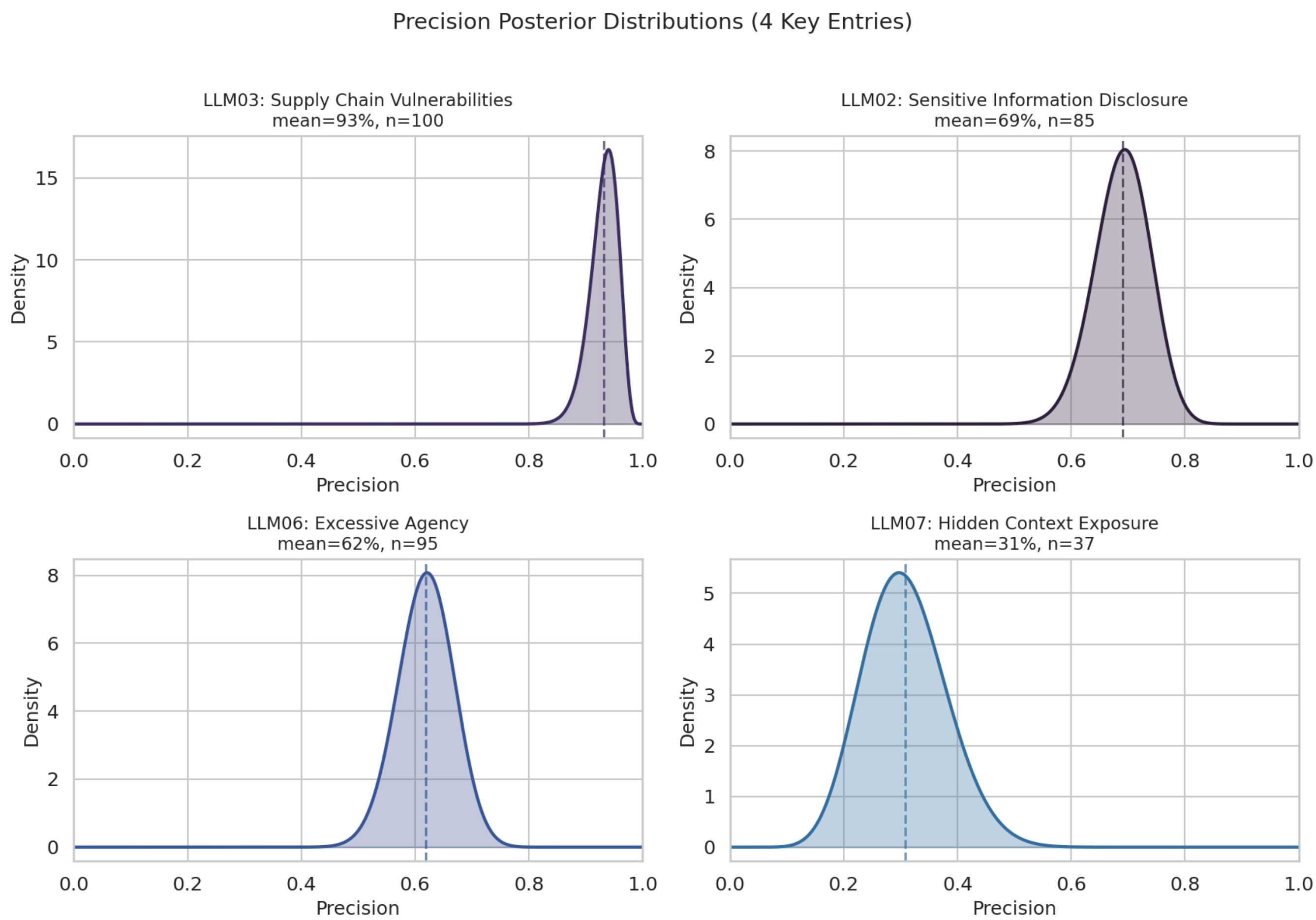
- **ROLL-CMSB (Cross-Modal Safety Bypass): 44%.** This entry sits at the center of the confusion boundary described in Act 9B. A deepfake video that bypasses content filters could be classified as ROLL-CMSB (cross-modal bypass), LLM09 (misinformation), or NEW-WLA (weaponized abuse). The classifier picks one; a human might reasonably pick any of the three.

## What the 50% threshold means

Precision below 50% means the classifier is **wrong more often than it is right** for that entry. When you see an incident labeled "LLM08," the odds are 7:1 against it actually being a vector/embedding weakness. This has direct consequences for the Bayesian model in Act 5: low-precision entries get large upward corrections (because much of their observed count is misclassification noise from other entries) and wide credible intervals (because the correction itself is uncertain). A 13% precision estimate does not mean the entry is unimportant — it means the *automated measurement* of that entry is unreliable, and the model's uncertainty reflects that.

**Stratum coverage note:** The 323 precision verifications were drawn entirely from the security stratum (CVE/GHSA/OSV). The ai-harm stratum (AIAAIC) has no precision measurements — the Bayesian model uses a flat Beta(1,1) prior for ai-harm precision, meaning it assumes no prior knowledge about classifier accuracy on those incidents (prior mean 0.5). This means error correction for ai-harm incidents relies on borrowed estimates, not direct measurement.






▶ **Deep dive: The gold-set process — 1,200 human adjudications**

▶ **Deep dive: Full precision posteriors table**

# Act 5: From Counts to Rankings — The Bayesian Model

Raw incident counts would be misleading. An entry whose classifier has 30% precision looks like it has many incidents — but two-thirds of those are misclassifications wrongly attributed to it.

We need a model that adjusts the observed counts for known classifier error. Think of a bathroom scale that reads 2 pounds heavy. You would subtract 2 pounds from every reading. The Bayesian model does this for each entry separately, and it carries the uncertainty through — if the scale is 2±1 pounds off, the corrected weight is also uncertain.

## What happens with low-precision entries

For entries above 50% precision, the correction is a moderate downward adjustment — some of the observed incidents were misclassified, so the true count is lower than the raw count. The correction tightens toward the true signal.

For entries **below 50% precision**, the correction works differently. If only 13% of incidents labeled "LLM08" actually belong there, the model must infer the true rate from a signal that is mostly noise. It's like reading a bathroom scale that is off by more than half the measurement — the "correction" is larger than the reading itself. This produces two effects: (1) the corrected estimate can be very different from the raw count, and (2) the uncertainty around that estimate is wide, because small changes in the precision estimate propagate into large changes in the corrected rate.

This is why some entries in the Act 6 chart have 90% credible intervals spanning 10+ rank positions. The width is not a flaw in the model — it is the model honestly reporting how much information the data contains about each entry's true incident rate.

## The model's inputs

The model takes the observed incident counts, the measured precision and recall for each entry, and produces a **posterior distribution** over the true incident rate for each entry. A posterior distribution is not a single number — it is a range of plausible values given the data. Wide distributions mean less certainty.

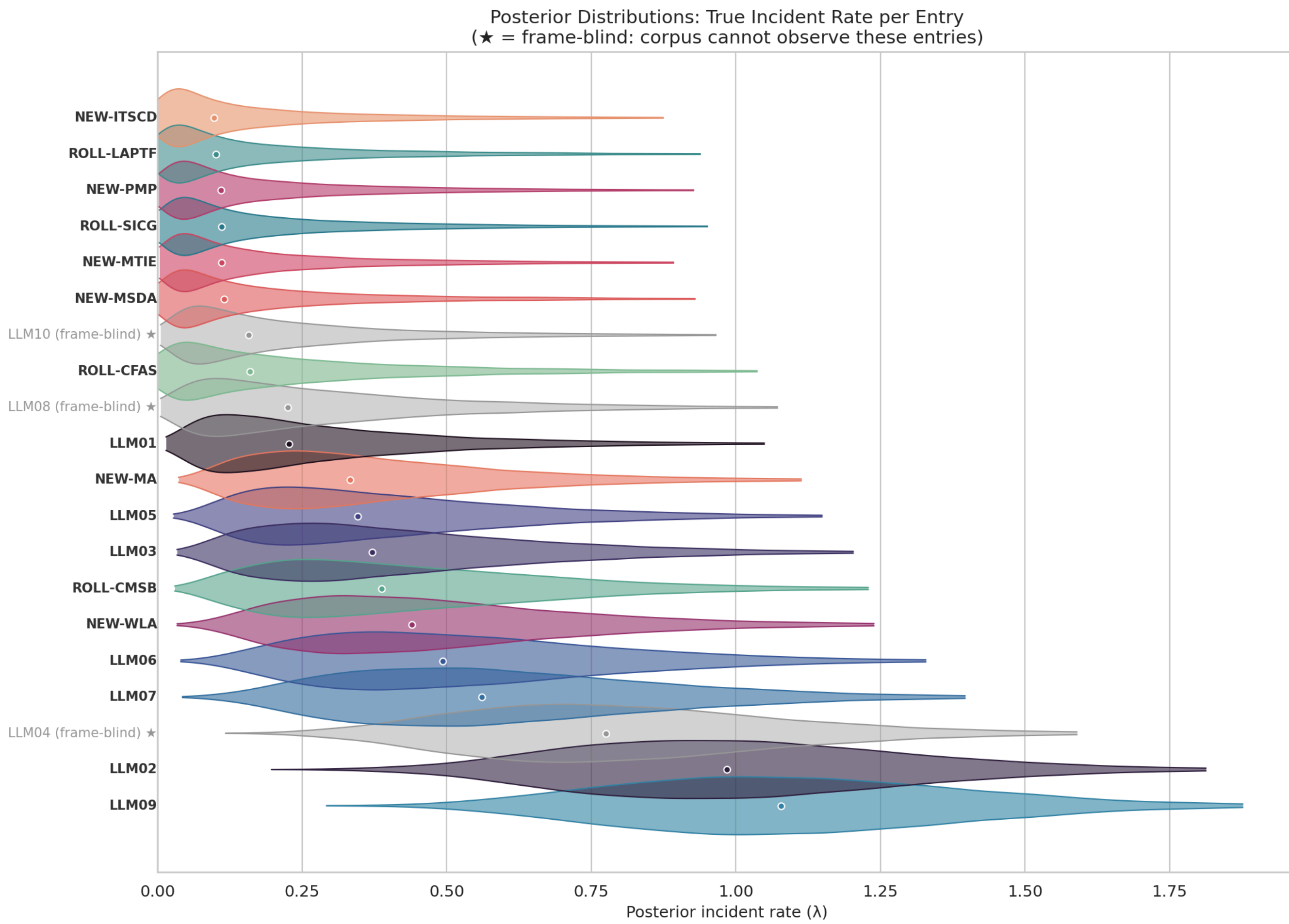
We drew 16,000 samples from this distribution using Markov chain Monte Carlo (MCMC). MCMC is a method for sampling from probability distributions that are too complex to compute directly. It generates a sequence of random samples that, after enough iterations, represents the target distribution. Our run used 4 chains of 4,000 samples each, with 2,000 warmup iterations per chain.

## Handling missing data

Three entries — LLM04, LLM08, LLM10 — are **frame-blind**: their incident counts come entirely from one stratum, so the model cannot cross-validate their rates across strata. These entries are included in the posterior but flagged with a ★ in the charts. Their rank estimates carry additional structural uncertainty beyond what the credible intervals capture.

**For 16 of 20 entries in the ai-harm stratum, we have not measured recall directly.** The model uses a conservative prior estimate of ~1% recall for those entries — Beta(1, 101). This means the model assumes the classifier finds very few of those incidents and adjusts upward accordingly. These corrections are large, which is one reason the credible intervals in Act 6 are wide.

**Precision in the ai-harm stratum is also unmeasured.** The model uses a flat Beta(1,1) = Uniform(0,1) prior, meaning it treats ai-harm precision as completely unknown (prior mean 50%). This is a weaker assumption than the security stratum, where we have 5–88 hand-verified observations per entry.



Posterior summary: median incident rate, 90% credible interval, diagnostic flag

| | Entry | Name | Median λ | 90% CI | CI Width | Diagnostic |
|---|---|---|---|---|---|---|
| **8** | LLM09 | Misinformation | 1.0784 | [0.6420, 1.6241] | 0.9821 | adequate |
| **1** | LLM02 | Sensitive Information Disclosure | 0.9846 | [0.5697, 1.5391] | 0.9694 | adequate |
| **3** | LLM04 | Data and Model Poisoning | 0.7755 | [0.4017, 1.3206] | 0.9189 | no-data |
| **6** | LLM07 | Hidden Context Exposure | 0.5607 | [0.2225, 1.1206] | 0.8981 | adequate |
| **5** | LLM06 | Excessive Agency | 0.4928 | [0.1848, 1.0388] | 0.8540 | adequate |
| **15** | NEW-WLA | Weaponized LLM Abuse | 0.4398 | [0.1621, 0.9733] | 0.8112 | adequate |
| **17** | ROLL-CMSB | Cross-Modal Safety Bypass | 0.3868 | [0.1207, 0.9315] | 0.8108 | adequate |
| **2** | LLM03 | Supply Chain Vulnerabilities | 0.3705 | [0.1198, 0.9167] | 0.7969 | adequate |
| **4** | LLM05 | Improper Output Handling | 0.3458 | [0.1157, 0.8683] | 0.7527 | adequate |
| **11** | NEW-MA | Model Misalignment | 0.3326 | [0.1147, 0.8349] | 0.7202 | adequate |
| **0** | LLM01 | Prompt Injection | 0.2271 | [0.0572, 0.7421] | 0.6849 | adequate |
| **7** | LLM08 | Vector and Embedding Weaknesses | 0.2255 | [0.0415, 0.7661] | 0.7246 | no-data |
| **16** | ROLL-CFAS | Compositional Fine-tuning Alignment Subversion | 0.1595 | [0.0135, 0.7240] | 0.7105 | wide |
| **9** | LLM10 | Unbounded Consumption | 0.1572 | [0.0317, 0.6540] | 0.6222 | no-data |
| **12** | NEW-MSDA | Model Scheming and Deceptive Alignment | 0.1147 | [0.0155, 0.6284] | 0.6128 | adequate |
| **13** | NEW-MTIE | MCP Tool Interface Exploitation | 0.1109 | [0.0169, 0.5900] | 0.5732 | adequate |
| **19** | ROLL-SICG | Systemic Insecure Code Generation | 0.1103 | [0.0159, 0.5997] | 0.5837 | adequate |
| **14** | NEW-PMP | Persistent Memory Poisoning | 0.1097 | [0.0142, 0.6035] | 0.5893 | adequate |
| **18** | ROLL-LAPTF | LLM Artifact Promotion Trust Failure | 0.1008 | [0.0079, 0.6074] | 0.5996 | wide |
| **10** | NEW-ITSCD | Inference-Time Side-Channel Disclosure | 0.0971 | [0.0097, 0.5796] | 0.5699 | wide |

▶ **Deep dive: The NumPyro model specification**

▶ **Deep dive: MCMC convergence diagnostics**

# Act 6: The Incident-Derived Rankings

These rankings reflect what the incident data suggests after correcting for classifier error. They are one signal, not the final word.

For each entry, the Bayesian model gives us a posterior distribution over its true incident rate. We rank entries by their median rate and report a 90% credible interval on the rank. Some entries have tight intervals (the data is informative) and others are wide (less certain). The width tells you how much to trust the rank position.

## How to read the chart

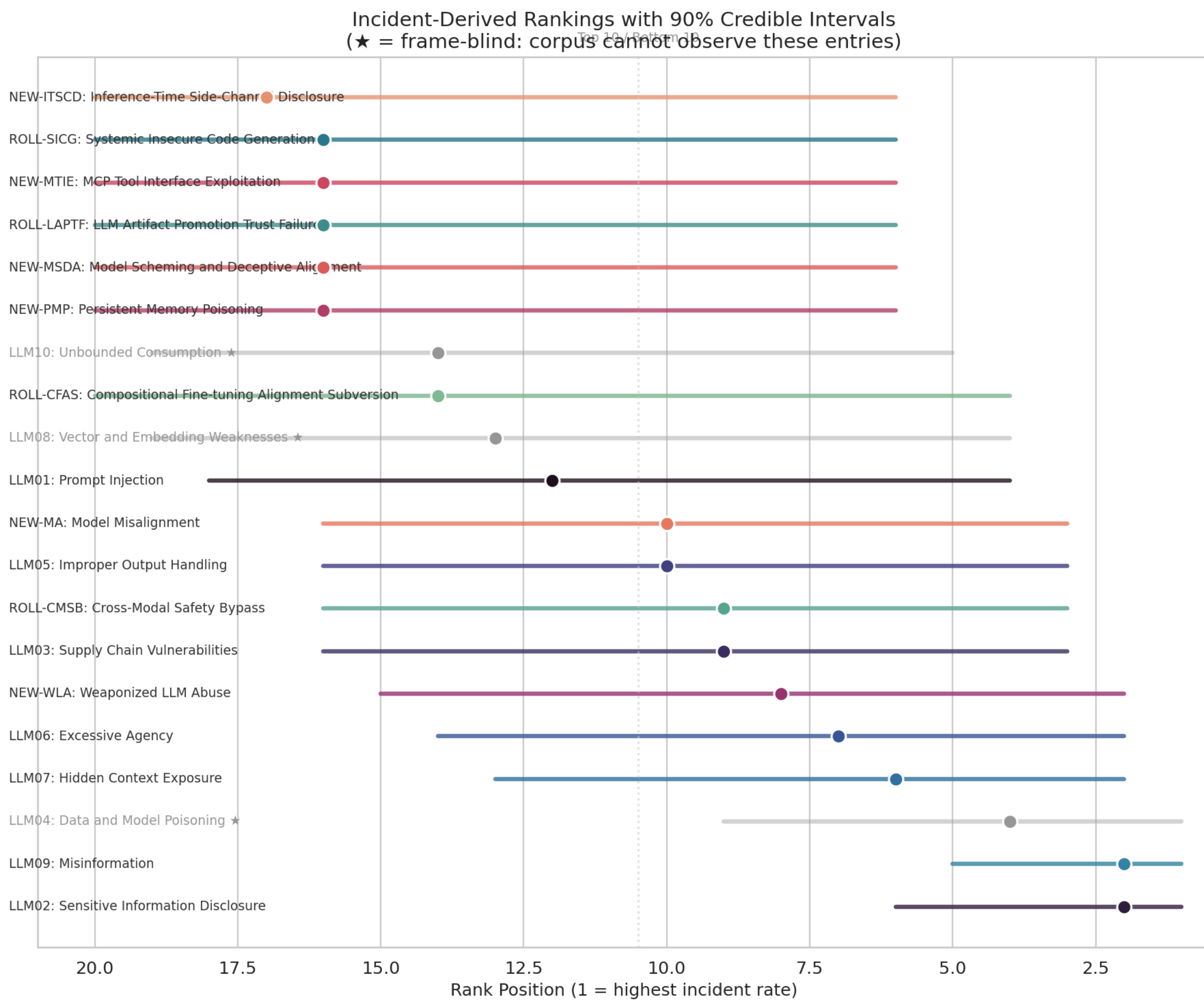
Each row is one taxonomy entry. The diamond marks the **median rank** — the rank position at the center of the posterior distribution. The horizontal bar spans the **90% credible interval** — the range of ranks that the model considers plausible given the data and its uncertainty about precision, recall, and the true incident rate.

**Tight intervals** (e.g., LLM02 spanning 1–6) mean the data strongly constrains that entry's position. Even after accounting for classifier error, the evidence points to a narrow range.

**Wide intervals** (e.g., spanning 6–20) mean the data is compatible with many rank positions. This happens when the entry has low precision (the correction is large and uncertain), few observations (small sample sizes produce wide posteriors), or unmeasured recall (the model uses a conservative prior that adds uncertainty).

**Grey entries** (LLM04, LLM08, LLM10) are frame-blind — their measurements come from only one stratum. Their positions carry structural uncertainty beyond what the CI captures.

The static matplotlib chart shows the rank distributions. The interactive plotly chart below it lets you hover over each entry for details: median rank, CI bounds, diagnostic flag, and frame-blind status.



Incident-Derived Rankings with 90% Credible Intervals
(★ = frame-blind: corpus cannot observe these entries)
Top 10 / Bottom 10
NEW-ITSCD: Inference-Time Side-Channel Disclosure
ROLL-SICG: Systemic Insecure Code Generation
NEW-MTIE: MCP Tool Interface Exploitation
ROLL-LAPTF: LLM Artifact Promotion Trust Failure
NEW-MSDA: Model Scheming and Deceptive Alignment
NEW-PMP: Persistent Memory Poisoning
LLM10: Unbounded Consumption ★
ROLL-CFAS: Compositional Fine-tuning Alignment Subversion
LLM08: Vector and Embedding Weaknesses ★
LLM01: Prompt Injection
NEW-MA: Model Misalignment
LLM05: Improper Output Handling
ROLL-CMSB: Cross-Modal Safety Bypass
LLM03: Supply Chain Vulnerabilities
NEW-WLA: Weaponized LLM Abuse
LLM06: Excessive Agency
LLM07: Hidden Context Exposure
LLM04: Data and Model Poisoning ★
LLM09: Misinformation
LLM02: Sensitive Information Disclosure
20.0
17.5
15.0
12.5
10.0
7.5
5.0
2.5
Rank Position (1 = highest incident rate)